SK Shieldus Rookies

경영진 보고

모의 교육 플랫폼 취약점 진단 결과

러닝브릿지(가상) 온라인 교육 플랫폼

전체 위험 수준	진단 일자	문서 번호	작성
심각	2026-10-02	SCAN-2026-001-E	SK쉴더스 루키즈 34기 1석삼조 팀

본 보고서는 SK쉴더스 루키즈 교육과정의 프로젝트 산출물이며, SK쉴더스의 공식 진단 보고서가 아닙니다.

외부인이 다른 회원의 개인정보를 쉽게 볼 수 있습니다

러닝브릿지의 온라인 교육 플랫폼에서 약 12만 명의 회원 개인정보가 노출될 위험이 있습니다. 일반 회원이 다른 회원의 개인정보를 조회할 수 있으며, 관리자 권한 없이도 일부 기능을 실행할 수 있습니다. 이러한 취약점은 개인정보 유출로 이어질 수 있습니다.

전체 위험 수준

심각

개인정보를 처리하는 자산에 '상' 위험 취약점이 있음

취약 항목

5 건 / 점검 6개 항목

상 4건, 중 1건, 하 0건

영향받는 개인정보 처리 자산

1 개

교육 플랫폼 웹서버

핵심 위험

1 누구나 추측할 수 있는 비밀번호로 가입할 수 있음 상

약한 비밀번호 정책으로 인해 외부인이 쉽게 계정에 접근할 수 있으며, 이는 개인정보 유출로 이어질 수 있습니다.

관련 법령 개인정보 보호법 제29조(안전조치의무) 검토 전
관련 법령 개인정보의 안전성 확보조치 기준 제5조 제5항(접근 권한의 관리) 검토 전
유사 사례 숙명여자대학교 · 비밀번호 규칙 미흡, 본인확인 미흡 동일 결함 **과징금 3,750만 원, 과태료 300만 원, 공표**
유사 사례 듀오정보 주식회사 · 로그인 실패 제한 없음, 비밀번호 규칙 미흡 동일 결함 **과징금 11억 9,700만 원, 과태료 1,320만 원, 공표명령**

2 주문번호만 알면 남의 개인정보를 볼 수 있음 상

불충분한 권한 검증으로 인해 일반 회원이 다른 회원의 개인정보를 조회할 수 있으며, 이는 심각한 개인정보 유출로 이어질 수 있습니다.

관련 법령 개인정보 보호법 제29조(안전조치의무) 검토 전
관련 법령 개인정보의 안전성 확보조치 기준 제5조 제5항(접근 권한의 관리) 검토 전
관련 법령 개인정보의 안전성 확보조치 기준 제6조 제3항(접근통제) 검토 전
유사 사례 경북대학교 · 파라미터 변조, 웹셸 업로드 동일 결함 **과징금 5,750만 원, 과태료 720만 원, 공표**
유사 사례 루이비통코리아(유) · 권한 확인 누락, 본인확인 미흡 동일 결함 **과징금 213억 8,500만 원, 공표명령**

3 무차별 대입 공격에 취약하여 계정 탈취 가능 상

불충분한 인증 절차로 인해 무차별 대입 공격이 가능하며, 이는 계정 탈취 및 개인정보 유출로 이어질 수 있습니다.

관련 법령 개인정보 보호법 제29조(안전조치의무) 검토 전

관련 법령 개인정보의 안전성 확보조치 기준 제5조 제5항(접근 권한의 관리) 검토 전

관련 법령 개인정보의 안전성 확보조치 기준 제6조 제3항(접근통제) 검토 전

유사 사례 ㈜엔라이즈 · 로그인 실패 제한 없음, 본인확인 미흡 동일 결함 **과징금 1억 1,844만 원, 과태료 360만 원**

유사 사례 ㈜티머니 · 크리덴셜 스터핑, 이상행위 탐지 미흡 동일 결함 **과징금 5억 3,400만 원, 시정명령, 공표명령**

관련 법령과 인증기준

조항·기준	관련 취약점	상태
개인정보 보호법 제29조(안전조치의무)	4건	검토 전
개인정보의 안전성 확보조치 기준 제5조 제5항(접근 권한의 관리)	4건	검토 전
개인정보의 안전성 확보조치 기준 제6조 제3항(접근통제)	2건	검토 전
ISMS-P 2.5.4 비밀번호 관리	2건	검토 전
ISMS-P 2.5.6 접근권한 검토	1건	검토 전
ISMS-P 2.5.2 사용자 식별	1건	검토 전
ISMS-P 2.5.3 사용자 인증	2건	검토 전
ISMS-P 2.10.3 공개서버 보안	1건	검토 전

유사 처분·보도 사례

과징금 처분 개인정보위 2023-10-12 동일 결함

숙명여자대학교 · 비밀번호 규칙 미흡, 본인확인 미흡

과징금 3,750만 원, 과태료 300만 원, 공표

과징금 처분 개인정보위 2026-04-23 동일 결함

듀오정보 주식회사 · 로그인 실패 제한 없음, 비밀번호 규칙 미흡

과징금 11억 9,700만 원, 과태료 1,320만 원, 공표명령

과징금 처분 개인정보위 2023-10-12 동일 결함

경북대학교 · 파라미터 변조, 웹셸 업로드

과징금 5,750만 원, 과태료 720만 원, 공표

과징금 처분 개인정보위 2026-02-12 동일 결함

루이비통코리아(유) · 권한 확인 누락, 본인확인 미흡

과징금 213억 8,500만 원, 공표명령

외 2건은 앞 장의 핵심 위험별 유사 사례에 있습니다.

'검토 전'은 AI가 매핑하고 담당자가 아직 확인하지 않은 항목입니다. 확정 전까지는 위반 소지로 보아야 합니다.
사례 등급: 동일 결함 = 인증기준과 취약점 유형이 모두 같음, 같은 유형 = 취약점 유형이 같음, 관련 통제 = 인증기준만 같음.

과징금 노출과 감경 여지

최대 노출액 (법정 상한)

1억 5,000만 원

연 매출 50억 원의 3%. 제29조(안전조치의무)에 취약점 4건이 걸려도 상한은 한 번만 적용

투자 감경 반영 시 (예시)

9,000만 원

보호 투자·조치 기록이 있으면 최대 40% 감경. 지금은 기록이 없어 감경 근거가 없음

10% 특례 시나리오

5억 원

반복 위반, 1천만 명 이상 피해, 시정명령 불이행으로 유출될 때만. 현재 요건 해당 없음

같은 유형 결함의 실제 과징금

유사 처분 14건 · 최소 329만 원 · 중앙값 5억 3,300만 원 · 최대 4,235억 7,500만 원

사례	처분일	과징금
쿠팡 주식회사 (유출 관련) · 권한 확인 누락, 본인확인 미흡 동일 결함	2026-06-11	**4,235억 7,500만 원**
SK스토아㈜ · 크리덴셜 스터핑, 이상행위 탐지 미흡 동일 결함	2025-01-22	**14억 3,200만 원**
강북구청 · 관리자 페이지 노출, 보안 패치 미적용 동일 결함	2026-03-26	**3억 7,800만 원**
현대자동차㈜ · 보안 패치 미적용, 개인정보 노출 같은 유형	2024-08-28	**329만 원**

법정 상한은 최대치이며 예상 부과액이 아닙니다. 실제 부과액은 과징금 부과기준의 산정 단계(기준금액, 감경, 조정)를 거쳐 정해집니다.
유사 사례 금액이 상한보다 큰 것은 사례 기업의 매출 규모가 더 크기 때문이며, 같은 결함이 실제로 처분받은 규모를 보여주기 위한 참고값입니다.

조치 로드맵

즉시 1주 이내

비밀번호 최소 길이·조합 규칙 서버 검증 추가

약한 비밀번호 정책

모든 페이지에 사용자 권한 검증 로직 구현

불충분한 권한 검증

로그인 실패 횟수 제한 및 계정 잠금 도입

불충분한 인증 절차

단기 1개월 이내

비밀번호 복구 절차 강화 및 임시 비밀번호 표시 제거

취약한 비밀번호 복구 절차

오류 화면 및 HTTP 응답 헤더 정보 노출 차단

정보 누출

중기 분기 이내

해당 없음

경영진 결정이 필요한 사항

1 비밀번호 정책 강화를 위해 즉시 조치를 승인해 주십시오.

2 회원 개인정보 보호를 위해 권한 검증 로직 구현을 승인해 주십시오.

3 보안 투자 기록 관리를 위한 예산과 책임자를 지정해 주십시오.

취약점별 상세 내용과 조치 방법은 실무진용 상세 보고서(SCAN-2026-001-T)에 있습니다. 법령·인증기준 매핑 중 17건은 아직 담당자 검토 전입니다.